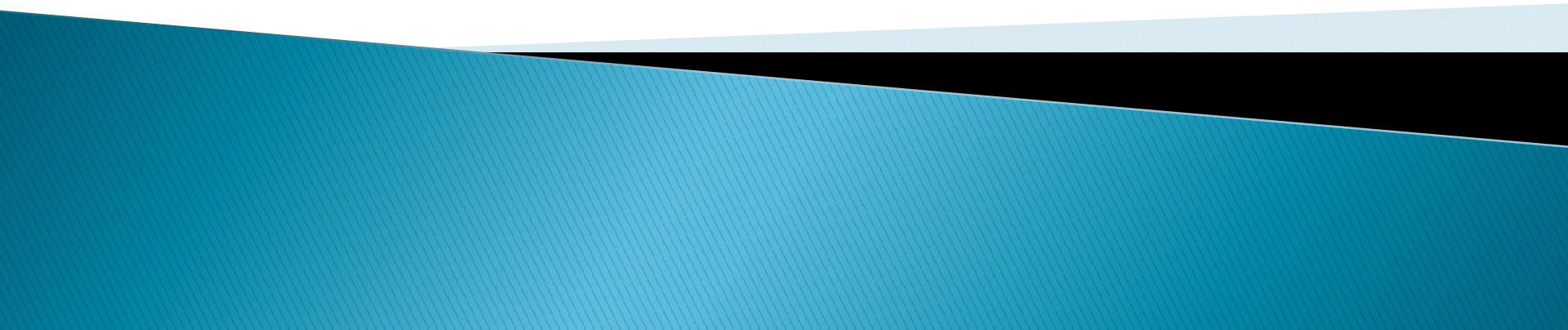


Computer Security and Cyber Law

Unit 7

Intrusion Detection

Lecturer: Binod Chandra Shrestha



Intrusion

- ▶ Entrance by force or without permission or welcome.
- ▶ Any set of actions that attempt to compromise the integrity, confidentiality or availability of a resource.
- ▶ The intentional insertion of electromagnetic energy into transmission paths in any manner with the objective of deceiving operators or of causing confusion.

Intruder

Someone who intrudes on the privacy or property of another without permission.

Intrusion Techniques

- ▶ The objective of the intruder is to gain access to a system or to increase the range of privileges accessible on a system.
- ▶ system must maintain a file that associates a password with each authorized user.

Intrusion Techniques

- ▶ The password file can be protected in one of two ways:
 - **One-way function:** The system stores only the value of a function based on the user's password. When the user presents a password, the system transforms that password and compares it with the stored value.
 - **Access control:** Access to the password file is limited to one or a very few accounts.

Intrusion Techniques

- ▶ Number of password crackers, reports the following techniques for learning passwords:
 - Try default passwords used.
 - Try all short passwords (those of one to three characters).
 - Try words in the system's online dictionary or a list of likely passwords.

Intrusion Detection

- ▶ Intrusions are the activities that violate the security policy of system.
- ▶ Intrusion Detection is the process used to identify intrusions.

Intrusion Detection

- ▶ Three systems models for an IDS
 - Anomaly detection
 - Misuse detection
 - Specification detection
 - new

Intrusion Detection

▶ Anomaly detection

- Assumes that unexpected behavior is evidence of an attack
- Compare set of variables and their values to a known set of variables
- Tries to reason about an attack based on data does not match
- Usually done with statistics but could be done with other variable techniques also

Intrusion Detection

▶ Anomaly Detection

◦ Threshold approach

- When an variable(s) are above a certain level determine an attack
- Example:
 - number of failed logins for a given user id in 10 minutes
 - disk usage
 - # of packets on port x in time period n

Anomaly Detection

- ▶ Threshold approach problems
 - Users have different skill levels
 - Example an asian user of an english comptur system
 - Class ?
 - One threshold generally applied to all
 - However approach can penalize new users by locking them out of the system

Anomaly Detection

- ▶ Statistical Moment Approach
 - Instead of setting a threshold, calculate:
 - Average
 - Means
 - Standard deviations
 - Look for deviations from these variable

Anomaly Detection

▶ Statistical Moment Approach

◦ Problems

- Data may change over time in unexpected ways
 - New users
 - Users become smarter
- Need to age data somehow to show how system is changing
- How do we do this ?
- Generally a better system than thresholds
- May use an expert system (Haystack, IDES)

Anomaly Detection

▶ State Machine Model

- Series of events occur in regular sequences
- Certain events are more likely to follow other events – state transitions
- When a low probability transition occurs then it is probably anomalous
- Draw: login, cd home dir → open word processor
- Can be utilized in system calls: open, read, write, close

Anomaly Detection

▶ State Machine

◦ Problems

- Need to know the events and sequences ahead of time
- Need training data
- System may change based on addition of new software
- Can only be run on the computer from which the training data is derived

Anomaly Detection

- ▶ What features and data variables to watch is critical in the success of AD
- ▶ Frank demonstrated that selection of the “best” features for a network activity classification program could be based on eliminating features based on the error rate they induce in classification of activity
 - He found that about 5 features was right for his study

Anomaly Detection

- ▶ Generally assumes a gaussian distribution
 - A bell curve that shows what is normal
- ▶ Some systems may cluster data by related values such as “read time” for a file and “cpu usage” for the read
 - Outliers – values that don’t fit into a cluster then can be an attack

Misuse Detection

- ▶ An attack by an insider who generally has authorized access
- ▶ Is rule based
- ▶ Looks for sequences of commands that knowing violate policy
- ▶ Example

Misuse Detection

- ▶ Rules are placed into a rule set
- ▶ Ids processes rules against system logs looking for violations of the rules
- ▶ Often involve expert systems because rules can be ambiguous

Misuse Detection

- ▶ Cant detect attacks that are unknown
 - the attacks sequence of rule violations is not known
- ▶ Can enhance systems to make them adaptive via petri nets

Misuse Detection

- ▶ IDIOT – Spafford, uses petri nets
- ▶ Defines
 - events – a change in system state
 - a record of the event
 - transitions from one state to another on an event
 - transitions may have tests (guards) that check for existence of variables in certain states and / or make assignments
 - Can have separate transition branches that merge

Misuse Detection

- ▶ IDIOT classified attacks by categories:
 - existence – attack creates a file
 - sequence – attack causes several events to occur sequentially
 - partial order – attack causes two or more sequences of events that form an ordering over time
 - interval – two events occur exactly n units of time apart

Misuse Detection

▶ IDIOT

- monitors audit trail logs
- STAT a similar system
 - Ilgun
 - No guards
 - uses state tables
 - looks at the sequence of command to e.g. get a forbidden privilege

Specification Modeling

- ▶ Misuse detection looks for states known to be bad
- ▶ Specification modeling looks for states known to not be good – a possible intrusion
- ▶ Builds specifications for how a program should run
- ▶ Examines program for deviations from good states

Specification Modeling

- ▶ Calvin Ko developed a specification based IDS
- ▶ Monitored 15 security related programs
- ▶ Monitored on things like:
 - object access
 - synchronization of data
 - sequences of commands
 - race conditions

Specification Modeling

- ▶ They looked at rdist (remote distribution)
- ▶ Rdist updates programs on remote systems
- ▶ Problem is that rdist modifies permissions on files
 - replacing a file with a symbolic link to another file, can get rdist to change permissions on that file

Specification Modeling

▶ SM

- utilizes grammars to specify actions
- grammars define acceptable activities
- is a relatively new field
- because it specifies what should happen
 - unknown attacks can be detected
- Class drawbacks ?

Architecture of IDS

- ▶ IDS works off of audit trails
- ▶ Audit trails found in logs
- ▶ Best to collect log data from all over the system due to distributed attacks
- ▶ Generally constructed in 3 subsystems
 - Agent
 - Director
 - Notifier

Architecture of IDS

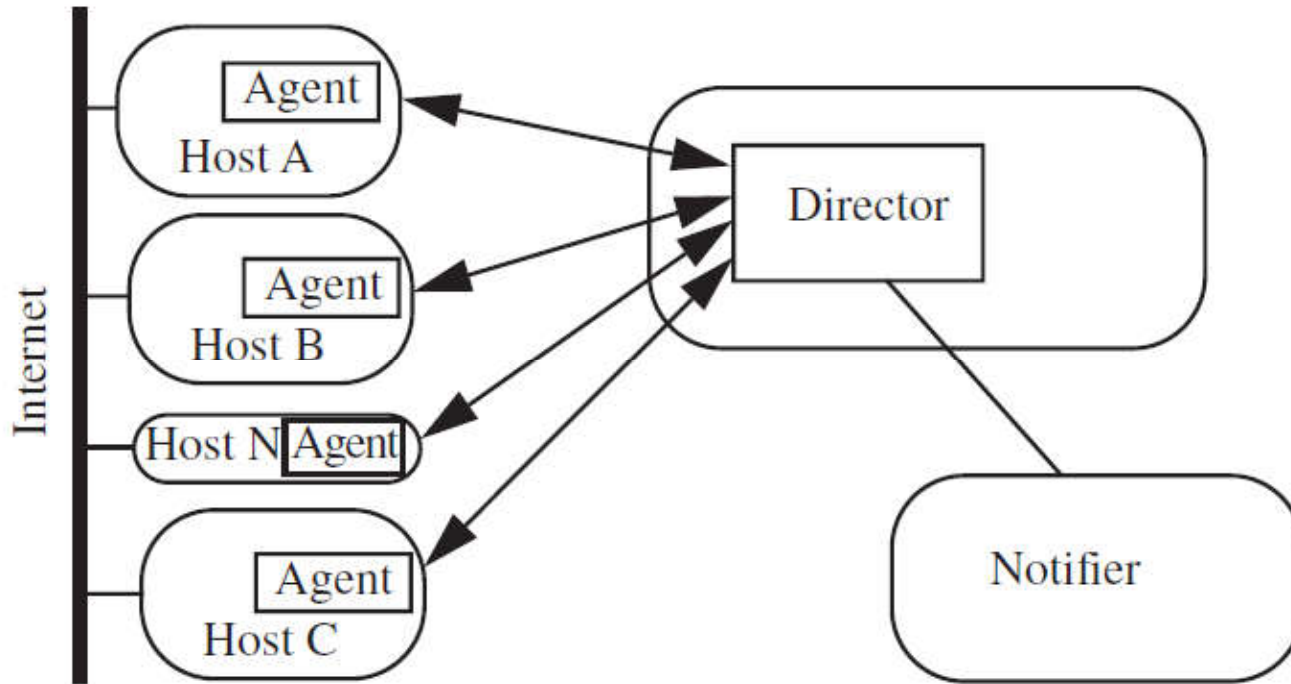


Fig. Architecture of an intrusion detection system. Hosts A, B, and C are general-purpose computers, and the agents monitor activity on them. Host N is designed for network monitoring, and its agent reports data gleaned from the Net to the director.

Architecture of IDS

▶ Agent

- an relatively autonomous piece of software that collects data from a local machine
- may format the data
- sends the data to a centralized system
- may pick over data that is not deemed to be important

Architecture of IDS

- ▶ Agents can be:
 - host based
 - utilize system and application logs
 - may be security logs or accounting logs
 - a virtual agent can be in the kernel and write data to logs it finds interesting
 - logs can be very large

Architecture of IDS

- ▶ Agents can be
 - networked based
 - use devices and software to monitor network traffic
 - used to detect network based attacks
 - utilize sniffing
 - monitor contents of packets
 - must be arranged in a way to provide full network coverage
 - encipherment makes this task a problem

Architecture of IDS

- ▶ Agents send formatted information to the director software
- ▶ Directors
 - eliminate unnecessary log entries
 - utilize an analysis engine to find attacks
 - usually are run on a separate system
 - adaptive directors may alter search rules (neural network)

Architecture of IDS

▶ Notifier

- accepts information from the director and takes appropriate action
- may notify a security officer via a gui
- may be proactive in combating an attack

Organization of IDS

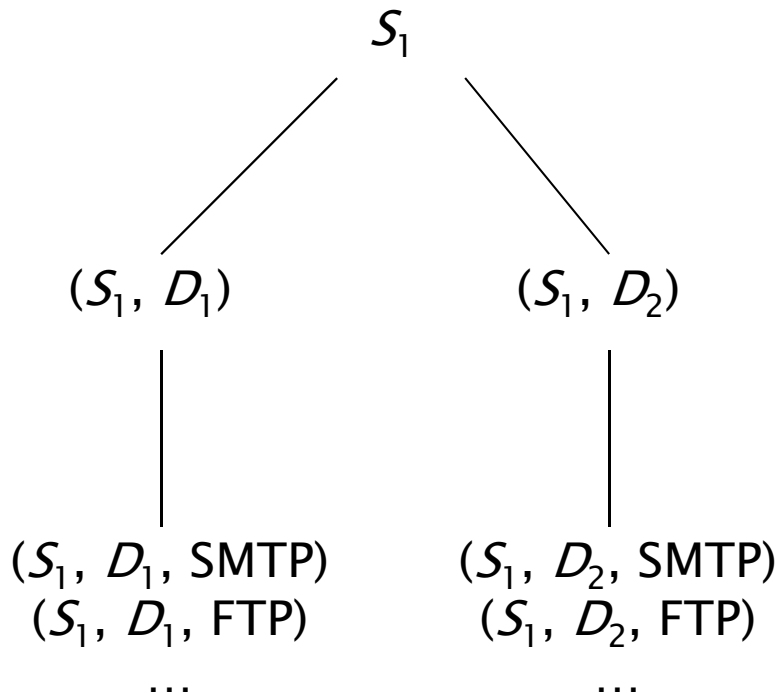
- ▶ An intrusion detection system can be organized in several ways. Here, we are exploring three such paradigms using research intrusion detection systems:
 - Monitoring network traffic for intrusions
 - NSM system
 - Combining host and network monitoring
 - DIDS
 - Making the agents autonomous
 - AAFID system

Organization of IDS

- ▶ Monitoring Networks: NSM
 - Develops profile of expected usage of network, compares current usage
 - Has 3-D matrix for data
 - Axes are source, destination, service
 - Each connection has unique *connection ID*
 - Contents are number of packets sent over that connection for a period of time, and sum of data
 - NSM generates expected connection data
 - Expected data masks data in matrix, and anything left over is reported as an anomaly

Organization of IDS

Problem



- ▶ Too much data!
 - Solution: arrange data hierarchically into groups
 - Construct by folding axes of matrix
 - Analyst could expand any group flagged as anomalous

Organization of IDS

▶ Signatures

- Analyst can write rule to look for specific occurrences in matrix
 - Repeated telnet connections lasting only as long as set-up indicates failed login attempt
- Analyst can write rules to match against network traffic
 - Used to look for excessive logins, attempt to communicate with non-existent host, single host communicating with 15 or more hosts

Organization of IDS

▶ Other

- Graphical interface independent of the NSM matrix analyzer
- Detected many attacks
 - But false positives too
- Still in use in some places
 - Signatures have changed, of course
- Also demonstrated intrusion detection on network is feasible
 - Did no content analysis, so would work even with encrypted connections

Organization of IDS

- ▶ Combining Host and Network Monitoring (DIDS)
 - DIDS: Distributed Intrusion Detection System
 - Combines network monitoring of NSM with host based intrusion detection
 - Why? Network would miss intruder logging into account without password, but host based might catch this after further action. Host would miss attacker who telnets with several user names, but network would catch this.

Organization of IDS

▶ DIDS

- DIDS director: centralized analysis engine
 - Rule based expert system that made inferences about both hosts and entire system
- Agents on hosts and monitoring network
- Example correlation: intruder accesses first system as Alice, second as Bob. DIDS would notice if Alice connected to a remote host and logged in to second system as Bob. Would then consider Alice and Bob to be same entity.

Organization of IDS

▶ Autonomous Agents

- process that can act independently of system of which it is part
- Different species of agent, each with own internal model and rules. When these are violated, agent notifies other agents (of its own and other species)
 - Hybrid vigor: an attacker who compromises one type of agent may know nothing about other types
 - Agent division of labor can make each type relatively simple

Organization of IDS

▶ Autonomous Agents

- Eliminates single point of failure (cooperation of agents creates distributed control)
- Scalability: agents can migrate through network and process data on multiple systems.
- Disadvantage: Communication costs
 - Simple agents means more agents needed to monitor system, hence greater communication costs.
 - Communications must be secured
- Distributed computation must be secured

Organization of IDS

- ▶ Autonomous Agents For Intrusion Detection (AAFID)
 - Each host has agents and *transceiver*
 - Transceiver controls agents (initiates and terminates them), collates info, forwards to monitor (if no monitor on host)
 - Filters: provide access to system resources in system-independent form.
 - Agents subscribe to filters (possibly many to a single filter)

Organization of IDS

▶ AAFID

- Monitors form the distributed control.
 - Communication with transceivers and other monitors
 - System must ensure consistency among monitors
- Implemented prototype runs on Linux and Solaris systems.
 - Written in Perl
 - Slow, but demonstrated that autonomous agent IDS is practical

Intrusion Response

- ▶ Goal: handle attempted attack in way such that damage is minimized. May also thwart attack.
- ▶ Incident Prevention
- ▶ Intrusion Handling
 - Containment
 - Eradication
 - Follow-Up

Intrusion Response

► Incident Prevention

- Want to detect and stop attacks before they succeed (so obviously attack needs to be identified before it completes)
- Jailing: Allow attacker to think they have succeeded, when in reality they are in confined area
 - Berford
- Somayaji and Forrest
 - Record anomolous system calls in locality frame buffer
 - When LFC exceeds predefined parameter, system calls delayed by $d \times 2^{**}LFC$ for d a tunable param.
 - If max LFC exceeded, system call blocked

Intrusion Response

▶ Intrusion Handling

- Preparation: Establishes procedures and mechanisms for detecting and responding to attacks
- Identification
- Containment: Limit damage of attack
- Eradication: Stop attack and block further similar attacks
- Recovery: Restore system to secure state
- Follow-up: Take action against adversary, identify problems in handling of incident, record lessons learned

Intrusion Response

► Containment

- Passive monitoring: Record actions for later use
 - Marginally useful
 - May reveal goals of attacker
 - System remains vulnerable, and intruder could attack other systems through this one
- Constrain actions of attacker
 - Considerably more difficult
 - Minimize protection domain while preventing attack from succeeding
 - May not know goals of attack (so above bullet requires guessing that may be wrong)

▶ Eradication Phase

- This means stopping the attack
- Need to deny access to system, either through breaking of network connection or termination of involved processes
- Wrappers: common means of implementing blocking
 - Wrappers implement various forms of access control
 - Wrappers kick in when attack detected
 - Fraser, Badger, Feldman used loadable kernel modules to place wrappers in kernels of UNIX systems
 - Could also be used to write audit logs, generate system call counts, etc
 - Can also control network access (e.g. wrap a database)

Intrusion Response

▶ Follow-Up Phase – Counterattacking

- Use legal procedures
 - Collect chain of evidence so legal authorities can establish attack was real
 - Check with lawyers for this
 - Rules of evidence very specific and detailed
 - If you don't follow them, expect case to be dropped
- Technical attack
 - Goal is to damage attacker seriously enough to stop current attack and deter future attacks

Assignment 7

1. What is intrusion detection? Explain the system models for intrusion detection system.
2. Explain architecture of intrusion detection system with its block diagram.
3. Describe the intrusion prevention procedure.
4. Explain different phases of intrusion handling.
5. Write short notes on:
 - a) NSM
 - b) DIDS
 - c) AAFID